

# CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-10 · Source: `pom.xml`

## Summary

| Metric                       | Count |
|------------------------------|-------|
| Total CVEs found             | 13    |
| <b>CRITICAL</b> dependencies | 1     |
| <b>HIGH</b> dependencies     | 4     |
| <b>MEDIUM</b> dependencies   | 1     |
| <b>LOW</b> dependencies      | 3     |
| Outdated dependencies        | 8     |
| License violations           | 2     |
| Supply-chain alerts          | 2     |

## Known-vulnerable dependencies

| Dependency                                  | Version    | Top CVE                    | CVSS | Severity        | Fix version |
|---------------------------------------------|------------|----------------------------|------|-----------------|-------------|
| org.apache.logging.log4j:log4j-core         | 2.14.1     | CVE-2021-44228 (Log4Shell) | 10.0 | <b>CRITICAL</b> | 2.17.1      |
| org.apache.logging.log4j:log4j-api          | 2.14.1     | CVE-2021-44228             | 10.0 | <b>CRITICAL</b> | 2.17.1      |
| com.fasterxml.jackson.core:jackson-databind | 2.9.8      | CVE-2019-14379             | 9.8  | <b>CRITICAL</b> | 2.13.4.2    |
| com.google.guava:guava                      | 24.1.1-jre | CVE-2023-2976              | 5.5  | <b>MEDIUM</b>   | 32.0.0-jre  |
| mysql:mysql-connector-java                  | 8.0.30     | — (GPL-2.0 license)        | —    | <b>MEDIUM</b>   | 8.0.33      |

## All CVEs (top dependencies)

| CVE            | Dependency             | CVSS | Severity        |
|----------------|------------------------|------|-----------------|
| CVE-2021-44228 | log4j-core / log4j-api | 10.0 | <b>CRITICAL</b> |
| CVE-2021-45046 | log4j-core             | 9.0  | <b>CRITICAL</b> |
| CVE-2021-44832 | log4j-core             | 6.6  | <b>MEDIUM</b>   |
| CVE-2021-45105 | log4j-core             | 5.9  | <b>MEDIUM</b>   |
| CVE-2019-14379 | jackson-databind       | 9.8  | <b>CRITICAL</b> |
| CVE-2019-14540 | jackson-databind       | 9.8  | <b>CRITICAL</b> |
| CVE-2020-36518 | jackson-databind       | 7.5  | <b>HIGH</b>     |
| CVE-2022-42003 | jackson-databind       | 7.5  | <b>HIGH</b>     |
| CVE-2018-10237 | guava                  | 5.9  | <b>MEDIUM</b>   |

|               |       |     |        |
|---------------|-------|-----|--------|
| CVE-2023-2976 | guava | 5.5 | MEDIUM |
|---------------|-------|-----|--------|

## Supply-chain alerts

**CRITICAL — Typosquatted dependency.** `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core` ; the coordinate does not exist on Maven Central. **Remove immediately.**

**HIGH — Untrusted repository.** `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). Remove or replace with HTTPS.

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 1.